Práctica 05 — Explotación guiada y evidencia

Semana 5 — Fase 2: Ofensiva controlada

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Duración	3 horas de laboratorio
Modalidad	4 grupos con roles rotativos
Entrega	Repositorio GitHub del grupo, carpeta semana_05, antes del corte semanal
Instrumento	control fase 2

1 Objetivo

Explotar de forma controlada inyección SQL, XSS y LFI, y explicar la causa raíz y el control que lo evita.

2 Contenidos que se aplican

- OWASP Top 10 2021 y categorías con mayor impacto.
- Control de acceso roto y exposición de datos sensibles.
- Inyección SQL, XSS reflejado y almacenado, LFI y RFI.
- Configuración insegura y componentes desactualizados.
- Evidencia reproducible, capturas y causa raíz en el código.

3 Escenario

Cada grupo explota tres vulnerabilidades en DVWA y resuelve tres retos de Juice Shop, documentando payload, evidencia, causa raíz y mitigación.

4 Procedimiento

1. Ejecutar un XSS reflejado en DVWA y capturar la evidencia del reflejo.
2. Ejecutar una inyección SQL que devuelva datos no previstos y documentar el payload.
3. Explotar un LFI para leer un archivo del sistema del contenedor.
4. Resolver tres retos de Juice Shop y anotar la pista y el razonamiento.
5. Para cada caso, identificar la línea de código o configuración responsable y el control que lo evita.

5 Entregable

Informe técnico con payloads, evidencia anonimizada, causa raíz y mitigación por hallazgo.

6 Rúbrica de corrección

Criterio	Peso
Explotación reproducible de los tres tipos de vulnerabilidad	3,0
Causa raíz correctamente identificada	2,5
Mitigación concreta y verificable por hallazgo	2,0
Evidencia clara y anonimizada	1,5
Retos de Juice Shop justificados	1,0
Total	**10,0**

Antes de empezar: confirma que el objetivo es un contenedor del laboratorio o un sistema con autorización escrita. Si no lo es, detente y consulta al docente: la práctica no se corrige sin ese requisito.